

Full Disk Encryption (FDE) e TPM

Gruppo di lavoro: DoSBusters

Natale Mastrogiacomo, S345071
Johnprice Osagie, S344613
Francesco Pusceddu, S349318
Francesco Ambrosino, S354781
Federico Farci, S347748
Ivan Guariento, S347630

Keywords: Full Disk Encryption, Trusted Platform Module, Hardware Root of Trust

1 Introduzione

Nell'attuale panorama digitale, la protezione delle informazioni non riguarda più soltanto la difesa dagli attacchi provenienti dalla rete, ma richiede una tutela rigorosa anche dei dati memorizzati fisicamente sui dispositivi (*data at rest*). La crescente diffusione di laptop, smartphone e sistemi di archiviazione portatili espone infatti le informazioni personali e professionali a rischi significativi in caso di furto, smarrimento o accesso fisico non autorizzato.

Come evidenziato nelle analisi pratiche sull'ecosistema Windows, la crittografia del disco è ormai considerata un requisito standard anche per gli utenti non specialisti: le più recenti versioni dei sistemi operativi consumer, come Windows 11 Home, iniziano, infatti, a integrarla automaticamente di default [1]. Questa evoluzione riflette la crescente consapevolezza della necessità di proteggere i dati anche quando un attaccante ottiene accesso diretto all'hardware.

Tuttavia, affidarsi esclusivamente alla cifratura software presenta limiti rilevanti. Gli studi sulle soluzioni tradizionali, come l'Encrypting File System (EFS) o la Full Disk Encryption (FDE) basata su password, mostrano due criticità strutturali: da un lato la gestione delle chiavi, spesso memorizzate localmente e quindi potenzialmente recuperabili tramite attacchi *brute-force*, dall'altro la cosiddetta decifratura trasparente, che espone l'intero contenuto del disco in chiaro dopo l'avvio del sistema, rendendolo vulnerabile a malware o accessi non autorizzati post-boot [2].

Per mitigare queste debolezze, l'evoluzione della sicurezza sta convergendo verso un modello *trusted*, fondato su componenti hardware dedicati. In questo contesto, il Trusted Platform Module (Trusted Platform Module (TPM):) svolge il ruolo di radice di fiducia (*Root of Trust*): un processore crittografico, ovvero un componente in grado di generare, custodire e utilizzare chiavi senza mai esporle al sistema operativo, vincolandone l'uso all'integrità dell'intera piattaforma di avvio [1].

Basandosi sui modelli teorici di Trusted Full Disk Encryption (TFDE) [2] e sugli approfondimenti tecnici disponibili nella letteratura recente [3], questa relazione esplora come l'integrazione tra FDE e TPM consenta di superare i limiti delle soluzioni tradizionali, rafforzando la protezione dei dati memorizzati e garantendo un avvio sicuro del sistema. Infine, vengono analizzate alcune implementazioni pratiche, come BitLocker e VeraCrypt [1], per comprendere in che modo tali strumenti bilancino sicurezza, usabilità e flessibilità operativa.

2 Descrizione della tecnica e degli scenari di utilizzo

La protezione dei dati *at rest* utilizza tecnologie crittografiche progettate per rendere le informazioni inaccessibili senza la chiave corretta. Per comprendere come il supporto hardware

possa elevare il livello di sicurezza, è utile analizzare i diversi livelli in cui la cifratura può essere applicata e il ruolo svolto dal TPM nei modelli più avanzati.

2.1 Full Disk Encryption (FDE) e File-Level Encryption (FLE)

Secondo l'analisi condotta da Raila [1], è possibile distinguere due approcci principali alla cifratura dei dati. Il primo è la **Full Disk Encryption (FDE)**, che cifra l'intero volume di archiviazione a livello di settori utilizzando algoritmi simmetrici ad alte prestazioni, come AES¹. In questo modello, tutto il contenuto del disco (dal sistema operativo ai file temporanei) risulta inaccessibile quando il computer è spento. Una volta sbloccato il volume, la cifratura opera in modalità *on-the-fly*, risultando completamente trasparente per l'utente. Soluzioni comuni includono Microsoft BitLocker per Windows e LUKS nei sistemi Linux.

Il secondo approccio è la **File-Level Encryption (FLE)**, che cifra singoli file o directory, creando compartimenti sicuri all'interno del sistema operativo. A differenza della FDE, la FLE consente di proteggere soltanto porzioni selezionate dei dati. Un esempio noto è VeraCrypt, utilizzato per creare contenitori cifrati o volumi nascosti a supporto di esigenze di riservatezza elevata.

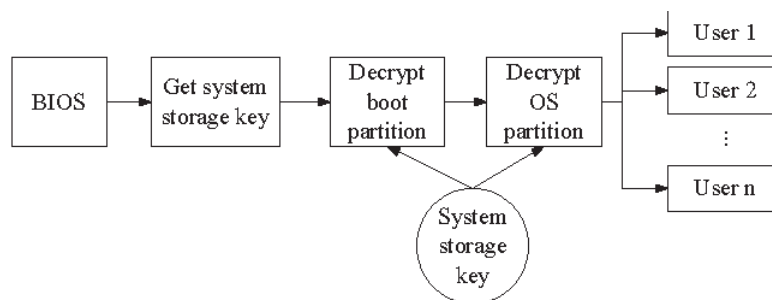


Figura 1: Diagramma di flusso del processo di avvio in un modello Trusted Full Disk Encryption (TFDE). Lo schema evidenzia la dipendenza critica dalla System Storage Key per la decrittazione sequenziale della partizione di boot e del sistema operativo, subordinando l'accesso degli utenti alla corretta acquisizione della chiave.

2.2 Il ruolo del TPM e la tecnica del Sealing:

Il limite strutturale della FDE puramente software risiede nella gestione delle chiavi: la *Volume Master Key* (Volume Master Key (VMK):), necessaria per decifrare il contenuto del disco, deve essere protetta tramite password o altri meccanismi software, esponendosi ad attacchi come brute-force o estrazione dalla memoria RAM. Il modello TFDE proposto da Li Jun e Yu Huiping [2] e ulteriormente approfondito da Zappulla [3] supera questo problema integrando un componente hardware dedicato: il **Trusted Platform Module (TPM)**.

Il TPM è un microchip presente sulla scheda madre che svolge due funzioni critiche per la protezione dello storage. La prima è la custodia della *Storage Root Key* (Storage Root Key (SRK):), una chiave che non lascia mai il chip e che viene utilizzata per cifrare tutte le altre chiavi del disco. La seconda funzione è il **Sealing**, ovvero la "sigillatura" delle chiavi ai valori dei registri di configurazione hardware, i *Platform Configuration Registers* (PCR)².

Il funzionamento si basa su una verifica di integrità all'accensione, durante la quale il TPM analizza l'intera catena di avvio: partendo dal firmware di base (BIOS), controlla le informazioni di partizionamento (Master Boot Record) fino a verificare il codice del bootloader incaricato di

¹AES è uno standard di cifratura simmetrica ampiamente adottato grazie alla sua efficienza e alla resistenza contro attacchi crittografici.

²I PCR sono registri hardware che memorizzano hash dei componenti del processo di avvio, consentendo di rilevare eventuali modifiche non autorizzate.

caricare il sistema operativo. Se un attaccante modifica uno di questi componenti (ad esempio tramite l'installazione di un *rootkit*) oppure tenta attacchi fisici diretti alla memoria volatile del sistema, i valori dei PCR variano rispetto a quelli previsti. In presenza di anomalie, il TPM rifiuta di rilasciare la chiave di decifratura, impedendo l'avvio del sistema e mantenendo i dati cifrati [2].

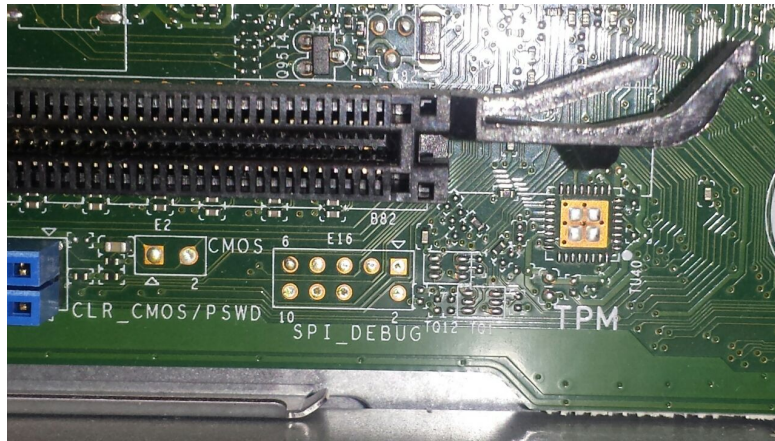


Figura 2: Esempio di microchip TPM su una scheda madre.

3 Analisi tecnica e debolezze sfruttate

3.1 Meccanismo tecnico della Full Disk Encryption con TPM

La protezione dei dati *at rest* viene realizzata cifrando l'intero volume di archiviazione mediante un algoritmo simmetrico ad alte prestazioni, tipicamente AES-XTS. La chiave che cifra i dati del disco (Volume Master Key, VMK) non viene memorizzata in chiaro, ma è protetta da una chiave master gestita dal Trusted Platform Module (TPM) [2, 3].

Durante la fase di avvio del sistema, il TPM misura l'integrità dei componenti critici della piattaforma firmware UEFI, *bootloader* e *kernel*, calcolandone gli hash e registrandoli nei Platform Configuration Registers (PCR). Questo processo stabilisce una catena di fiducia che vincola l'uso della VMK a uno specifico stato della piattaforma. Solo se i valori dei PCR corrispondono a quelli attesi, il TPM esegue l'operazione di Unsealing: e rilascia la chiave necessaria allo sblocco del volume cifrato. In caso contrario, l'accesso ai dati rimane negato e il contenuto del disco resta cifrato.

3.2 Limiti e vulnerabilità del modello

Nonostante l'efficacia del modello di Full Disk Encryption basato su TPM, esistono debolezze sfruttabili in scenari di attacco avanzati. Quando il sistema è acceso o in stato di sospensione, le chiavi di cifratura sono presenti nella memoria RAM; un attaccante con accesso fisico può quindi tentare un Cold Boot Attack:, sfruttando il fenomeno della persistenza residua dei dati (*data remanence*) per recuperare informazioni sensibili dopo un riavvio forzato [4].

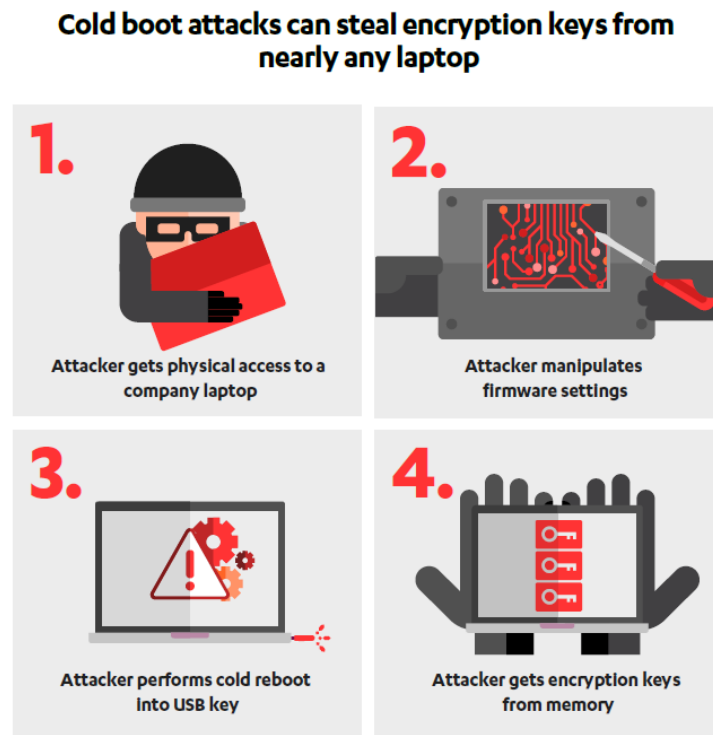


Figura 3: Passi di cui si compone un Cold Boot Attack: L'attaccante esegue un riavvio forzato della macchina caricando un proprio programma, ad esempio da una chiavetta USB. Poiché i dati rimangono "impressi" nella memoria per brevi istanti (a causa del fenomeno della persistenza residua), l'attaccante riesce a leggere ed estrarre le chiavi di cifratura prima che svaniscano definitivamente.

Ulteriori vulnerabilità emergono nelle implementazioni firmware del TPM (fTPM), diffuse nelle architetture consumer. Studi recenti hanno dimostrato che, tramite tecniche di Fault Injection, è possibile estrarre lo stato interno del modulo e aggirare completamente la protezione della Full Disk Encryption. Anche i TPM hardware discreti (dTPM) non sono esenti da rischi: attacchi Side-Channel Attack, come i *timing attacks*, possono in alcuni casi consentire il recupero delle chiavi private analizzando i tempi di esecuzione delle operazioni crittografiche [5, 6].

4 Casi reali

4.1 Compromissione dell'AMD fTPM

Un primo caso reale riguarda lo studio *faultTPM* [7], in cui viene analizzata l'implementazione firmware del TPM (fTPM) nei processori AMD recenti. Gli autori mostrano che, applicando un attacco di *fault injection* sul bus di alimentazione della CPU, è possibile eseguire un firmware modificato all'interno dell'AMD Secure Processor. In questo modo riescono a recuperare il segreto interno da cui vengono derivate le chiavi usate per cifrare lo stato non volatile del TPM, salvato su memoria flash. Una volta ottenuto questo segreto, l'attaccante può leggere e decifrare offline tutto lo stato del TPM, compresi gli oggetti sigillati che contengono le chiavi della Full Disk Encryption. L'errore di progettazione principale è l'assunzione che un fTPM in un TEE sia "forte" quanto un TPM hardware dedicato, e che quindi sia sicuro legare l'intera protezione del disco alla sola integrità del TPM. Questo è particolarmente critico nelle configurazioni BitLocker "TPM-only", dove nessun PIN o passphrase contribuisce alla sicurezza crittografica: una volta compromesso l'fTPM, il disco cifrato può essere montato e letto senza ulteriori sforzi.

4.2 Schema TPM+PIN implementato male

Nello studio citato nella sezione precedente viene analizzata anche l'integrazione tra LUKS2 e TPM tramite lo strumento *systemd-cryptenroll*. L'idea di base è fornire una protezione "TPM + PIN" per sbloccare il disco cifrato: in teoria, l'utente inserisce un PIN *pre-boot* e il TPM rilascia un segreto solo se piattaforma e PIN sono corretti. Nella pratica, però, l'implementazione analizzata genera un segreto casuale che viene sigillato nel TPM e usato direttamente per proteggere il *keyslot* LUKS, mentre il PIN entra solo nella policy interna del TPM (cioè decide se il TPM rilascia o meno il segreto). Questo significa che, se un attaccante riesce a compromettere l'fTPM e a decifrarne lo stato, può recuperare il segreto e sbloccare il disco indipendentemente dal PIN: il PIN non partecipa al *KDF* che protegge la chiave del disco. L'errore di progettazione è confondere il controllo di accesso al TPM con la protezione crittografica della chiave: in uno schema robusto il PIN dovrebbe contribuire direttamente alla derivazione della chiave che cifra il *keyslot*, così da mantenere sicurezza anche in caso di compromissione del TPM.

4.3 Limiti strutturali di EFS e FDE tradizionale

Un secondo studio analizzato [2] discute diversi problemi concreti dei sistemi di cifratura tradizionali, come EFS (Encrypting File System) e FDE senza integrazione sicura con TPM. Nel caso di EFS, viene evidenziato che durante la cifratura dei file vengono create copie temporanee nella stessa directory, poi semplicemente "cancellate" marcando i blocchi come liberi. Un attaccante con strumenti forensi può recuperare questi dati, smentendo l'idea che tutto sia davvero protetto. Inoltre, EFS cifra il contenuto ma lascia nomi dei file e struttura delle directory in chiaro, esponendo metadati potenzialmente sensibili. Un ulteriore limite è che chiavi e dati risiedono sulla stessa macchina, quindi chi ottiene accesso fisico al disco può puntare direttamente alle aree dove sono memorizzate le chiavi. Anche la FDE classica mostra debolezze: dopo il boot, l'intero file system è disponibile in chiaro al sistema operativo, quindi malware o utenti interni possono leggere tutto. Spesso esiste una singola chiave di disco condivisa da più utenti, senza separazione reale dei privilegi. Infine, la mancanza di strategie di *recovery* ben progettate può portare a perdite totali di dati. Qui l'errore non è un singolo bug, ma un insieme di scelte progettuali che non considerano a fondo scenari di attacco fisico e comportamenti reali degli utenti.

5 Conclusioni e discussione

L'analisi condotta evidenzia come l'integrazione tra Full Disk Encryption (FDE) e Trusted Platform Module (TPM) rappresenti un passo avanti fondamentale rispetto alle soluzioni puramente software. Il passaggio a un modello *Trusted*, vincolando la decifratura all'integrità della piattaforma tramite il meccanismo di *Sealing*, mitiga efficacemente molte delle debolezze strutturali dei sistemi tradizionali, come la gestione insicura delle chiavi e la vulnerabilità ai *rootkit*.

Tuttavia, la discussione dei casi reali dimostra che introdurre l'uso di hardware non è una soluzione universale. Infatti, abbiamo visto come gli fTPM di AMD possano essere compromessi tramite *Fault Injection* e la costante minaccia rappresentata dagli attacchi fisici, come i *Cold Boot Attack*, ci portano a due considerazioni critiche:

- **L'importanza della *defense in depth*:** Affidarsi alla modalità "TPM-only" (decifratura trasparente) favorisce l'usabilità ma espone a rischi elevati se il chip o il firmware vengono compromessi. È quindi importante adottare un approccio che combini più fattori di sicurezza, combinando per esempio il possesso dell'hardware (TPM) con una conoscenza segreta (PIN o passphrase).

- **La correttezza dell'implementazione:** Come evidenziato nell'analisi dello schema LUKS con *systemd-cryptenroll*, aggiungere un PIN non basta se questo viene usato esclusivamente per il controllo d'accesso. Per una sicurezza reale, il segreto dell'utente deve partecipare matematicamente nella derivazione (o costruzione) della chiave, in modo tale che la compromissione del solo TPM non sia sufficiente a sbloccare il disco.

In conclusione, mentre tecnologie come AES-XTS garantiscono la robustezza crittografica del dato at rest, la sicurezza complessiva del sistema dipende dalla protezione delle chiavi *in transit* (nella RAM) e *in use*. Per gli scenari ad alto rischio, dove è necessario un livello molto alto di sicurezza, è consigliabile fare uso di TPM hardware (dTPM), al posto di quelli firmware, combinandoli con l'adozione dell'autenticazione pre-boot. Questa soluzione rappresenta il compromesso ideale tra usabilità e protezione delle informazioni.

Glossario

Cold Boot Attack: Attacco che sfrutta la persistenza residua dei dati nella RAM dopo un riavvio improvviso, permettendo il recupero di chiavi crittografiche. 3

Fault Injection: Tecnica di attacco che altera intenzionalmente parametri fisici del dispositivo, come tensione o clock, per indurre comportamenti anomali e accedere a dati protetti dal TPM. 4

Sealing: Operazione tramite cui il TPM “sigilla” una chiave, rendendone l’uso possibile solo se i PCR corrispondono allo stato previsto della piattaforma. 2

Side-Channel Attack: Attacco che ricava informazioni sensibili analizzando parametri fisici come tempi di esecuzione, consumi energetici o emissioni elettromagnetiche, potenzialmente compromettendo chiavi protette dal TPM. 4

Storage Root Key (SRK): Chiave radice generata dal TPM e utilizzata per proteggere le altre chiavi del sistema. Non lascia mai il modulo e costituisce la base della sicurezza delle operazioni di cifratura. 2

Trusted Platform Module (TPM): Componente hardware dedicato alla sicurezza che genera e protegge chiavi crittografiche, rilasciandole solo se la piattaforma risulta integra. 1

Unsealing: Operazione mediante la quale il TPM rilascia una chiave precedentemente sigillata, solo se i valori dei PCR corrispondono allo stato atteso della piattaforma. 3

Volume Master Key (VMK): Chiave principale utilizzata per cifrare il contenuto del disco nelle soluzioni di Full Disk Encryption. 2

Riferimenti bibliografici

- [1] Dominykas Raila. Disk encryption on windows: practical evaluation, 2025. Technical report.
- [2] Li Jun and Yu Huiping. Trusted full disk encryption model based on tpm. In *The 2nd International Conference on Information Science and Engineering*, pages 1–4, 2010.
- [3] Damiano Zappulla. *Secure Boot and Monitoring for Embedded System*. PhD thesis, Politecnico di Torino, 2022.
- [4] J. Alex Halderman, Seth D. Schoen, Nadia Heninger, William Clarkson, William Paul, Joseph A. Calandrino, Ariel J. Feldman, Jacob Appelbaum, and Edward W. Felten. Lest we remember: Cold boot attacks on encryption keys. In *Proceedings of the 17th USENIX Security Symposium*, pages 45–60, 2008.
- [5] Robert Buhren, Christian Werling, and Jean-Pierre Seifert. faultpm: Exposing amd ftpms’ deepest secrets. *arXiv preprint arXiv:2304.14717*, 2023.
- [6] Daniel Moghimi, Berk Sunar, Thomas Eisenbarth, and Nadia Heninger. Tpm-fail: Tpm meets timing and lattice attacks. *arXiv preprint arXiv:1911.05673*, 2019.
- [7] Hans Niklas Jacob, Christian Werling, Robert Buhren, and Jean Pierre Seifert. *faulTPM: Exposing AMD fTPMs’ Deepest Secrets*. PhD thesis, Technische Universitat Berlin, 2023.